B5 — Segurança e Controle de Acesso

1. Perfis de acesso e princípio do menor privilégio

No banco de dados academia_avaliacao, foram definidos três perfis de acesso:

- **Administrador:** possui permissões amplas para administrar os objetos do banco de dados do projeto.
- **Funcionário:** possui permissões de consulta e inserção de dados, sem permissão de atualização no banco.
- **Consulta:** possui permissão para consultar somente a visão vw_alunos_consulta, que apresenta um conjunto limitado de informações dos alunos.

Os comandos GRANT e REVOKE foram utilizados para conceder e remover permissões. Essa abordagem aplica o princípio do menor privilégio, segundo o qual cada usuário deve receber apenas as permissões necessárias às suas atividades.

2. Proteção dos dados pessoais

O sistema trabalha com informações pessoais como nome, CPF, data de nascimento, telefone, e-mail, endereço e matrícula. Também mantém avaliações físicas, medidas antropométricas e informações de treinamento, que exigem cuidados adicionais por poderem revelar aspectos relacionados à saúde e à condição física.

Para reduzir a exposição dessas informações, foi criada a visão vw_alunos_consulta, que disponibiliza apenas identificador, nome, matrícula e situação da matrícula. O perfil de consulta recebe acesso a essa visão, sem acesso direto às tabelas de origem.

3. Armazenamento seguro de senhas

Foi criada a tabela usuario_aplicacao para armazenar as contas da aplicação. A proteção das senhas foi implementada em Java utilizando PBKDF2 com HMAC-SHA-256, salt aleatório e 600.000 iterações.

A tabela armazena o hash da senha, o salt e o número de iterações utilizados. A senha original não é armazenada. Um teste confirmou que a senha correta é validada e que uma senha incorreta é rejeitada.

O cadastro seguro de usuários foi implementado, mas a autenticação por tela de login ainda precisa ser integrada para que o mecanismo seja utilizado no acesso cotidiano à aplicação.

4. Medidas adicionais de segurança

Como medidas complementares, recomenda-se utilizar contas individuais, senhas fortes, credenciais de banco de dados restritas, consultas parametrizadas com PreparedStatement, tratamento adequado de erros, backups protegidos e acesso limitado aos dados pessoais. As credenciais não devem ser armazenadas diretamente no código-fonte.

5. Conclusão

A implementação do B5 estabeleceu perfis de acesso com permissões distintas, aplicou o princípio do menor privilégio, restringiu a visualização de dados pessoais por meio de uma visão e implementou o armazenamento de senhas com hash e salt. Essas medidas contribuem para a confidencialidade e a integridade das informações da academia. A integração do login e a validação final das permissões complementam a segurança da solução.